

Consent API Onboarding

Expose one authenticated endpoint. We read it; we never touch your database, and we never write.

01 Build the endpoint

One read-only route over the consent records you already hold.

```
GET https://your-domain.example/consent-api/consents?limit=500
x-api-key: <your key>           // we also send Authorization: Bearer <key>

→ 200  [ {...}, {...} ]         // array, or { "results": [ ... ] }
→ 401  { "error": "Invalid API key" }
```

Generate the key with `openssl rand -hex 24` and keep it in an environment variable. Reject any request whose key does not match with **401** — never an empty list, never a redirect.

02 Return these fields

FIELD	TYPE	WHY IT MATTERS
user_id req	string	Stable identifier for the person
email req	string	Or any contact identifier you hold
consent_status req	enum	<code>granted</code> · <code>revoked</code> · <code>pending</code>
timestamp req	ISO 8601	When the record was created
WITHOUT THESE, THE MATCHING COMPLIANCE CHECK REPORTS "NOT MEASURED"		
purpose	string	Purpose limitation (s.5 notice)
consent_granted_at	ISO 8601	When consent was given
consent_revoked_at	ISO 8601 · null	Withdrawal — starts the erasure clock
pii_deleted_at	ISO 8601 · null	Actual erasure (s.12)
is_minor	boolean	Triggers the children's-data rules (s.9)
guardian_verified	boolean	Whether parental consent was verified

```
{
  "user_id": "1042",
  "email": "asha@example.com",
  "consent_status": "granted",
  "timestamp": "2026-07-09T17:18:43.870Z",
  "purpose": "Marketing",
  "consent_granted_at": "2026-07-09T17:18:43.870Z",
  "consent_revoked_at": null,
  "pii_deleted_at": null,
  "is_minor": false,
  "guardian_verified": false
}
```

03 Add whatever else you hold

Column names are recognised automatically — send them as they are.

pan · aadhaar · account_number · ifsc · upi · card_number · gstin · abha · policy_number ·
passport · phone · address · date_of_birth · kyc · diagnosis

Identifiers with a checkable structure are validated, so a real PAN or bank account is recognised as such rather than guessed from its column name.

Never send secrets. Passwords, hashes, tokens, PINs and OTPs have no place in a consent record and are flagged at maximum severity.

04 Optional: declare who you share data with

A second route at `/processors`, next to your consent route. A 404 is fine.

```
[
  { "name": "Mailchimp", "purpose": "Marketing email",
    "dataCategories": ["email", "name"], "location": "United States",
    "dpaSigned": true, "dpaExpiry": "2027-01-01" }
]
```

Sharing personal data without a contract is a violation of s.8(2), and this is how you evidence one exists. Anything outside India counts as a cross-border transfer.

05 Check it before sending

```
# must return records
curl -s -H "x-api-key: $KEY" "https://your-domain.example/consent-api/consents?limit=2"

# both must print 401
curl -s -o /dev/null -w "%{http_code}\n" "https://your-domain.example/consent-api/consents"
curl -s -o /dev/null -w "%{http_code}\n" -H "x-api-key: wrong" "https://your-domain.example/consent-api/consents"
```

- Reachable over HTTPS from the public internet, valid certificate
- Send us the **full path** to the route, not just your domain
- Responds well within 20 seconds — we time out there
- We re-read every 5 minutes

Send the endpoint URL and API key over a secure channel — that is all we need. No database credentials, no VPN, no schema. Rotating the key is one line on your side; revoking it stops the integration immediately.